



Superseed: Crosschain ERC20 Security Review

Cantina Managed review by:

0xRajeev, Lead Security Researcher
Cryptara, Security Researcher

June 4, 2025

Contents

1	Introduction	2
1.1	About Cantina	2
1.2	Disclaimer	2
1.3	Risk assessment	2
1.3.1	Severity Classification	2
2	Security Review Summary	3
3	Findings	4
3.1	Informational	4
3.1.1	Unsafe mint destinations may trap funds or confuse tooling	4
3.1.2	Unaudited dependencies with potentially latent issues may be risky	4

1 Introduction

1.1 About Cantina

Cantina is a security services marketplace that connects top security researchers and solutions with clients. Learn more at cantina.xyz

1.2 Disclaimer

Cantina Managed provides a detailed evaluation of the security posture of the code at a particular moment based on the information available at the time of the review. While Cantina Managed endeavors to identify and disclose all potential security issues, it cannot guarantee that every vulnerability will be detected or that the code will be entirely secure against all possible attacks. The assessment is conducted based on the specific commit and version of the code provided. Any subsequent modifications to the code may introduce new vulnerabilities that were absent during the initial review. Therefore, any changes made to the code require a new security review to ensure that the code remains secure. Please be advised that the Cantina Managed security review is not a replacement for continuous security measures such as penetration testing, vulnerability scanning, and regular code reviews.

1.3 Risk assessment

Severity	Description
Critical	<i>Must fix as soon as possible (if already deployed).</i>
High	Leads to a loss of a significant portion (>10%) of assets in the protocol, or significant harm to a majority of users.
Medium	Global losses <10% or losses to only a subset of users, but still unacceptable.
Low	Losses will be annoying but bearable. Applies to things like griefing attacks that can be easily repaired or even gas inefficiencies.
Gas Optimization	Suggestions around gas saving practices.
Informational	Suggestions around best practices or readability.

1.3.1 Severity Classification

The severity of security issues found during the security review is categorized based on the above table. Critical findings have a high likelihood of being exploited and must be addressed immediately. High findings are almost certain to occur, easy to perform, or not easy but highly incentivized thus must be fixed as soon as possible.

Medium findings are conditionally possible or incentivized but are still relatively likely to occur and should be addressed. Low findings a rare combination of circumstances to exploit, or offer little to no incentive to exploit but are recommended to be addressed.

Lastly, some findings might represent objective improvements that should be addressed but do not impact the project's overall security (Gas and Informational findings).

2 Security Review Summary

Superseed is a network that transforms Ethereum scaling into self-repaying loans.

From May 13th to May 14th the Cantina team conducted a review of [superseed-crosschainERC20](#) on commit hash [01d05098](#). The team identified a total of **2** issues:

Issues Found

Severity	Count	Fixed	Acknowledged
Critical Risk	0	0	0
High Risk	0	0	0
Medium Risk	0	0	0
Low Risk	0	0	0
Gas Optimizations	0	0	0
Informational	2	1	1
Total	2	1	1

3 Findings

3.1 Informational

3.1.1 Unsafe mint destinations may trap funds or confuse tooling

Severity: Informational

Context: [CrosschainERC20.sol#L31](#)

Description: The `CrosschainERC20.crosschainMint()` and `XERC20.mint()` functions do not enforce any restrictions on the `_to` address. Given that this contract inherits from Solady's ERC20, the underlying `_mint()` implementation explicitly allows minting to the zero address (`address(0)`) and to the contract itself (`address(this)`). Although this behavior may be deliberate in Solady for gas optimization and standard flexibility, in practice, minting to these addresses can be a source of bugs or trapped funds.

Minting to `address(0)` could confuse downstream tooling or users, as this address is traditionally associated with token burns. Tokens minted to the contract's own address (`address(this)`) may result in trapped funds unless explicitly retrieved via internal logic, which currently does not exist in the contract.

Recommendation: Introduce validation logic to disallow minting to `address(0)` unless there is a compelling use case and clear documentation supporting it. Similarly, consider restricting minting to `address(this)` unless the contract implements logic to make use of those tokens. If such edge cases are needed for future protocol operations (e.g., internal accounting), explicitly document them and ensure safe handling of balances at these addresses.

Superseed: Fixed in commit [cf991a89](#).

Cantina Managed: Reviewed that commit [cf991a89](#) fixes the issue as recommended by preventing mints to `address(0)` and `address(this)`, and also on transfers.

3.1.2 Unaudited dependencies with potentially latent issues may be risky

Severity: Informational

Context: *(No context files were provided by the reviewer)*

Description: `CrosschainERC20` is a token implementation that combines [ERC-7281/XERC20](#) and [ERC-7802](#) functionality. While the `CrosschainERC20` contract in scope itself is a simple implementation of the two ERC-7802 specific functions, it inherits from [Defi-Wonderland's implementation of XERC20](#), which is more complex.

However, that XERC20 implementation was audited back in July 2023 ([Connexx_xTokens_Audit-Creed-v0.3.pdf](#)). Since then, there appear to have been many changes (32 closed PRs, including the port from OpenZeppelin to Solady for their ERC20 and Ownable contracts). Given that XERC20 is a critical dependency here and is out-of-scope for review, this is a dependency risk.

Similarly, the supporting contracts of `CrosschainERC20Factory` and `ERC7802Adapter` were also out-of-scope for this review.

Recommendation: While these supporting dependencies were spot-checked for context, they may have latent architectural and integration issues that may introduce security risks. They may have undergone an internal review but consider getting an external review to increase the level of confidence.

Superseed: Acknowledged.

Cantina Managed: Acknowledged.